



GamaSport

PARTE 4 DE 5

Seguridad y panel del personal

Quién puede ver y hacer qué, qué se encontró al auditar y cómo trabaja el personal.

Te toca hablar

5:30 a 7:30

Proyecto académico

DIA-309 · UNAH · II PAC 2026

Tu parte en una página

Qué mostrar en pantalla mientras hablas

- Mi cuenta con la sesión de un cliente, mostrando que solo ve sus reservas.
- El panel: cambiar el estado de una reserva y bloquear un horario.
- El catálogo después del bloqueo, para ver que esa hora desapareció.

Preguntas que te pueden hacer

La clave de Firebase se ve en el código, ¿eso no es un riesgo?

Se ve a propósito: así funciona toda aplicación web, porque el navegador necesita esa clave para hablar con el servicio. La seguridad real está en las reglas de Firestore, que se aplican del lado de Google y deciden quién puede leer y escribir cada cosa.

¿Dónde se guardan las contraseñas?

En Firebase Authentication, transformadas de forma irreversible. El sitio nunca las ve ni las guarda. Recuperar la contraseña manda un correo con un enlace, así que nadie puede cambiar la clave de otra persona sabiendo su correo.

¿Un cliente podría ver las reservas de otro?

No. Se probó pidiendo esos datos directamente a la base de datos sin sesión y el servidor los rechazó. La restricción no está en el navegador, está en Firebase.

¿Cómo se vuelve administrador alguien?

Con un documento en la colección de autorizados, que solo se crea desde la consola de Firebase. No hay contraseña de administrador escrita en el código.

Lo que sigue son los apartados completos de la documentación que te corresponden. El documento entero, con las dieciocho secciones, está en [docs/GamaSport-Documentacion.pdf](#).

9. Cuentas de usuario y seguridad

Quién puede entrar y cómo

TIPO	CÓMO ENTRA	QUÉ ALCANZA
Visitante	Sin cuenta.	Ver el catálogo, los precios y qué horas están libres.
Invitado	Se le crea una identidad temporal al confirmar una reserva.	Solo sus propias reservas. Si después se registra con correo, conserva las que hizo.
Cliente	Correo y contraseña.	Su perfil y su historial de reservas. Nada de otros clientes.
Personal	Correo y contraseña, más una autorización que solo se otorga desde la consola de Firebase.	Todas las reservas, los precios, los cupos, los horarios bloqueados y la lista de clientes.

Las contraseñas

El sitio **nunca guarda ni ve las contraseñas**. Cuando alguien se registra, la contraseña viaja cifrada a Firebase Authentication, que la guarda transformada de manera irreversible. Al iniciar sesión, Firebase la verifica y devuelve una credencial temporal que dura una hora y se renueva sola. Recuperar la contraseña envía un correo con un enlace, así que nadie puede cambiar la clave de otra persona con solo conocer su correo.

Las reglas de la base de datos

La clave del proyecto de Firebase viaja dentro del sitio y cualquiera puede verla: así funciona toda aplicación web. Por eso la seguridad real no está en esconder esa clave, sino en las reglas del archivo `firestore.rules`, que se aplican del lado de Google y no se pueden saltar desde el navegador.

INFORMACIÓN	QUIÉN PUEDE LEERLA	QUIÉN PUEDE MODIFICARLA
Horas ocupadas	Cualquiera, porque el calendario debe funcionar sin iniciar sesión. No incluye datos de personas.	Quien tenga sesión, solo para apartar su hora.
Reservas	El cliente que la hizo, y el personal.	Solo el personal cambia su estado.
Perfiles de clientes	El propio cliente y el personal.	Solo el propio cliente.
Precios y cupos	Cualquiera, porque salen en el catálogo.	Solo el personal.
Lista de autorizados	Cada quien puede consultar si él mismo lo está.	Nadie desde el sitio. Solo desde la consola de Firebase.

Hallazgo de la auditoría y corrección aplicada

En una revisión de seguridad se encontró que la base de datos estaba abierta: cualquiera con la dirección del sitio podía leer los nombres, correos y teléfonos de los clientes, y también borrar o falsear reservas. Además, la contraseña del panel estaba escrita dentro del código, a la vista de cualquiera que abriera el archivo.

Ambas cosas se corrigieron: hoy las reglas cierran el acceso, cada quien ve solo lo suyo, y el permiso de administrador ya no depende de una contraseña escrita en el código sino de una autorización que solo se otorga desde la consola de Firebase. El caso ilustra un principio del desarrollo web: la seguridad de un sitio no depende de su diseño ni de su código, sino de las reglas que definen quién puede hacer qué.

10. El panel administrativo

Está en `admin.html`, no aparece en el menú y los buscadores tienen instrucción de no indexarlo. Entrar requiere una cuenta autorizada; una cuenta de cliente normal recibe un aviso de que no tiene permisos.

Qué se puede hacer desde ahí

- **Ver el resumen:** reservas totales, pendientes, ingresos registrados, horarios bloqueados, servicios disponibles y usuarios registrados.
- **Gestionar reservas:** cada una con su cliente, teléfono, fecha, total y método de pago. El estado se cambia entre pendiente, confirmada, atendida y cancelada.
- **Editar el catálogo:** cambiar el precio y los cupos de cada servicio, u ocultarlo del catálogo sin borrarlo. Hay un botón para restaurar los valores originales.
- **Ver los clientes registrados** con su nombre, correo, fecha de registro y cuántas reservas llevan.
- **Bloquear horarios** por mantenimiento, ligas privadas o eventos. Un horario bloqueado desaparece de las opciones del cliente.

Cancelar una reserva libera automáticamente esa cancha en el calendario, para que otro cliente pueda tomarla.

11. El asistente de preguntas frecuentes

Es el botón redondo que aparece abajo a la derecha. **No es inteligencia artificial:** es una lista de catorce preguntas con sus respuestas escritas a mano.

Cuando alguien escribe, el texto se compara con las palabras clave de cada pregunta. Las palabras largas pesan más que las cortas, porque "cancelar" dice mucho más que "como". Gana la respuesta con más coincidencias, y si ninguna coincide se ofrece el contacto por WhatsApp. Responde sobre precios, horarios, cómo reservar, promociones, formas de pago, cancelaciones, torneos, restaurante, membresías, parqueo, capacidad y ubicación.

Glosario

17. Glosario

TÉRMINO	QUÉ SIGNIFICA
Sitio estático	Un sitio cuyos archivos se entregan tal cual, sin que un programa los arme en el servidor cada vez.
HTTPS	La versión cifrada de la conexión web. Impide que alguien en la misma red lea lo que se envía.
Base de datos en la nube	Un lugar en internet donde se guarda la información de forma permanente, accesible desde cualquier dispositivo.
Reglas de seguridad	Las condiciones que decide el servidor sobre quién puede leer o escribir cada dato. No se pueden saltar desde el navegador.
Autenticación	Comprobar que alguien es quien dice ser, normalmente con correo y contraseña.
Sesión anónima	Identidad temporal que el sistema asigna a quien usa el sitio sin registrarse, para poder distinguir sus datos de los de otros.
Almacenamiento local	Espacio del navegador donde el sitio guarda datos, como el carrito, que sobreviven al cerrar la página.
Service worker	Programa pequeño que el navegador ejecuta aparte y permite que el sitio responda sin conexión.
Diseño adaptable	Que la misma página se acomode bien tanto en celular como en computadora.
Repositorio	La carpeta del proyecto con todo su historial de cambios.
ISV	Impuesto Sobre Ventas. En Honduras su tasa general es del 15 %.
CAI	Clave de Autorización de Impresión, el código que autoriza la emisión de facturas fiscales.